

Cover

Network Reconnaissance and Vulnerability Assessment Lab

Dominic Yeakel

Instructor: Andry Rakotomalala

8/4/2026

# Part 1

1. Confirm your Kali VM's IP address and the lab subnet (provided at the start of class).  
Subnet: 10.10.20.0
2. Discover live hosts on the lab subnet: `nmap -sn <lab-subnet>/24`  
Only host running is the victim machine: 10.10.20.4
3. Run a full port and service/version scan against the target host: `nmap -sV -sC -p- <target-ip> -oN`  
Executed: `nmap -sV -sC -p- 10.10.20.4`
4. Record every open port, service, and version number in your findings table (Deliverable 1).

| Port  | Service       | Version                                      |
|-------|---------------|----------------------------------------------|
| 21    | FTP           | FileZilla ftpd 1.12.6                        |
| 80    | HTTP          | Microsoft IIS httpd 10.0                     |
| 135   | msrpc         | Microsoft Windows RPC                        |
| 139   | netbios-ssn   | Microsoft Windows netbios-ssn                |
| 445   | microsoft-ds? |                                              |
| 1433  | ms-sql-s      | Microsoft SQL Server 2019 15.00.2000.00; RTM |
| 3389  | RDP           | Microsoft Terminal Services                  |
| 5985  | WinRM (http)  | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)      |
| 47001 | WinRM         | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)      |
| 49664 | msrpc         | Microsoft Windows RPC                        |
| 49665 | msrpc         | Microsoft Windows RPC                        |
| 49666 | msrpc         | Microsoft Windows RPC                        |
| 49667 | msrpc         | Microsoft Windows RPC                        |
| 49668 | msrpc         | Microsoft Windows RPC                        |
| 49669 | msrpc         | Microsoft Windows RPC                        |
| 49671 | msrpc         | Microsoft Windows RPC                        |

|       |       |                       |
|-------|-------|-----------------------|
| 50766 | msrpc | Microsoft Windows RPC |
|-------|-------|-----------------------|

5. For each service and version you found, search for known exploits: searchsploit "<service> <version>"

| Microsoft Windows SQL Server - Remote Denial of Service (MS03-031)                |                          | windows/dos/65.c |
|-----------------------------------------------------------------------------------|--------------------------|------------------|
| Shellcodes: No Results                                                            |                          |                  |
| Exploit Title                                                                     | Path                     |                  |
| CitectSCADA ODBC Server - Remote Stack Buffer Overflow (Metasploit)               | windows/remote/6387.rb   |                  |
| CoreFTP Server build 725 - Directory Traversal (Authenticated)                    | windows/remote/50652.txt |                  |
| EaseUS Data Recovery - 'ensserver.exe' Unquoted Service Path                      | windows/local/50886.txt  |                  |
| Easy Chat Server 3.1 - Remote Stack Buffer Overflow (SEH)                         | windows/remote/50999.py  |                  |
| Emerson PAC Machine Edition 9.80 Build 8695 - 'TrapiServer' Unquoted Service Path | windows/local/50745.txt  |                  |
| Microsoft Windows Server 2000 - 'telnet.exe' NTLM Authentication                  | windows/remote/20222.cpp |                  |
| Microsoft Windows Server 2000 - RunAs Service Denial of Service                   | windows/dos/21099.c      |                  |
| Microsoft Windows Server 2000 - RunAs Service Named Pipe Hijacking                | windows/local/21069.c    |                  |
| Oracle WebLogic Server 14.1.1.0.0 - Local File Inclusion                          | windows/remote/50688.txt |                  |
| Sambar Server 4.3/4.4 Beta 3 - Search CGI                                         | windows/remote/20223.txt |                  |
| TCQ - ITeCProteccioAppServer.exe - Unquoted Service Path                          | windows/local/50902.txt  |                  |
| TermTalk Server 3.24.0.2 - Arbitrary File Read (Unauthenticated)                  | windows/remote/50638.txt |                  |
| TRIGONE Remote System Monitor 3.61 - Unquoted Service Path                        | windows/local/50633.txt  |                  |
| TYPSoft FTP Server 0.7.x - FTP Server Remote Denial of Service                    | windows/dos/20228.pl     |                  |
| WiFi Mouse 1.7.8.5 - Remote Code Execution(v2)                                    | windows/remote/50972.py  |                  |
| Wing FTP Server 4.3.8 - Remote Code Execution (RCE) (Authenticated)               | windows/remote/50720.py  |                  |

(Every other service came up empty)

6. Run Nmap's vulnerability-detection scripts against the target: nmap --script vuln <target-ip>

```
(student01@kali)~$ nmap --script vuln 10.10.20.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 19:32 +0000
Stats: 0:02:05 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.46% done; ETC: 19:34 (0:00:01 remaining)
Nmap scan report for victim.internal.cloudapp.net (10.10.20.4)
Host is up (0.0011s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-enum:
|   /admin/: Possible admin folder
|   /admin/index.html: Possible admin folder
|   /Admin/: Possible admin folder
|_ /backup/: Possible backup
|_http-dombased-xss: Couldn't find any DOM based XSS.
135/tcp   open  mspc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1433/tcp  open  ms-sql-s
|_tls-ticketbleed: ERROR: Script execution failed (use -d to debug)
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Nmap done: 1 IP address (1 host up) scanned in 143.51 seconds
```

7. Cross-reference anything flagged against the National Vulnerability Database ([nvd.nist.gov](http://nvd.nist.gov)) to confirm the CVE and read its description and CVSS score.

8. Rank each vulnerability you found as High, Medium, or Low priority based on CVSS score and how exposed the service is.

CVE-2012-1182 - 10 (HIGH)

9. For every vulnerability you identified — not just the one you exploited — propose a specific fix. Tie each recommendation back to one of these mitigation strategies covered on Day 1:

- Implementing secure network protocols and encryption in place of the vulnerable/legacy service
- Segmenting the network so a compromise of this host can't reach core banking systems
- Patching, hardening, or decommissioning the vulnerable service/version entirely

Write one to two sentences per vulnerability explaining specifically what you'd change and why it closes the gap you found — generic advice like "patch the system" won't be enough; name the service, the version, and the fix.

- HTTP
  - Close the port to prevent data being transferred in plain-text
- SQL
  - Update SQL Server to patch vulnerabilities (Version CU32 (build 15.0.4430.1))